

Sistema de Gerenciamento de PETs

VULNERABILITY REPORT

WEDNESDAY, NOVEMBER 19, 2025





MODIFICATIONS HISTORY

Version	Date	Author	Description
1.0	11/19/2025	Leonardo Sanga	Initial Version



TABLE OF CONTENTS

1.	General Information	4
1.1	Scope	4
1.2	Organisation.....	4
2.	Executive Summary.....	5
3.	Technical Details.....	Error! Bookmark not defined.
3.1	title	12
4.	Vulnerabilities summary	6



GENERAL INFORMATION

SCOPE

Sancet - Pet Management System has mandated us to perform security tests on the following scope:

- <http://98.89.42.45>

ORGANISATION

The testing activities were performed between 11/07/2025 and 11/19/2025.



EXECUTIVE SUMMARY



VULNERABILITIES SUMMARY

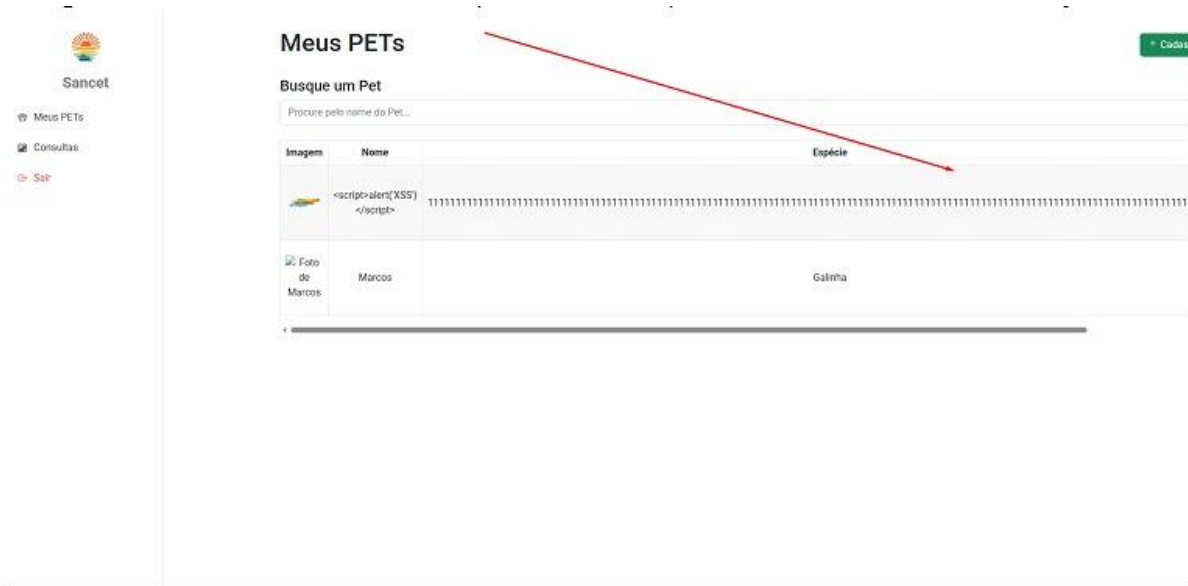
Following vulnerabilities have been discovered:

Risk	ID	Vulnerability	Affected Scope
Critical	IDX-003	SQL Injection	
	IDX-004	Upload of Malicious Files	
	IDX-005	Session Hijacking	
High	IDX-002	Privilege Escalation	
High	IDX-001	Insecure Direct Object Reference (IDOR)	



TECHNICAL DETAILS

SQL INJECTION

CVSS SEVERITY	Critical		CVSSv3 SCORE	10.0
CVSSv3 CRITERIAS	Attack Vector :	Network	Scope :	Changed
	Attack Complexity :	Low	Confidentiality :	High
	Required Privileges :	None	Integrity :	High
	User Interaction :	None	Availability :	High
AFFECTED SCOPE				
DESCRIPTION	SQL Injection ocorre quando a aplicação usa dados fornecidos pelo usuário para montar consultas SQL sem validação adequada. Isso permite que um atacante injete comandos SQL próprios, fazendo o banco executar consultas não previstas.			
OBSERVATION				
TEST DETAILS É possível inserir muitos caracteres em um campo sem nenhuma limitação, quebrando o design do site, além de colocar caracteres especiais, sendo possível realizar um injeção de SQL.  Image 1 – Inserção ilimitada de caracteres				
REMEDIATION	Eliminar completamente a construção dinâmica de queries baseada em dados fornecidos pelo usuário. Evite concatenar strings em qualquer etapa do processo. Valide e sanitize toda entrada do usuário, restringindo formatos e valores somente ao que é esperado. Restrinja permissões no banco de dados.			



REFERENCES	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/05-Testing_for_SQL_Injection
------------	---

UPLOAD OF MALICIOUS FILES

CVSS SEVERITY	Critical		CVSSv3 SCORE	9.9
CVSSv3 CRITERIAS	Attack Vector :	Network	Scope :	Changed
	Attack Complexity :	Low	Confidentiality :	High
	Required Privileges :	Low	Integrity :	High
	User Interaction :	None	Availability :	High
AFFECTED SCOPE				
DESCRIPTION	Aplicações que permitem upload de arquivos podem aceitar arquivos aparentemente legítimos, mas com conteúdo malicioso. A vulnerabilidade ocorre quando a aplicação permite o envio desses arquivos sem analisá-los ou filtrá-los adequadamente.			
OBSERVATION				
TEST DETAILS				
É possível carregar arquivos no campo de imagem que não seja do formato correto.				
				
Image 2 – image.png				



Image 3 – Carregado arquivo em formato não esperado

REMIEDIATION	Validar rigorosamente todos os arquivos enviados antes de armazená-los ou processá-los. Armazene os arquivos fora do diretório público da aplicação para impedir execução direta via URL. Desabilite permissões de execução nos diretórios de upload. Implemente listas de permissões (allowlist) de extensões e tamanhos, renomeie arquivos enviados e remova metadados perigosos. Em funcionalidades que lidam com imagens, utilize rotinas de reprocessamento.
REFERENCES	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/10-Business_Logic_Testing/09-Test_Upload_of_Malicious_Files

CVSS SEVERITY	Critical		CVSSv3 SCORE	9.6
CVSSv3 CRITERIAS	Attack Vector :	Network	Scope :	Changed
	Attack Complexity :	Low	Confidentiality :	High
	Required Privileges :	None	Integrity :	High
	User Interaction :	Required	Availability :	Low
AFFECTED SCOPE				



DESCRIPTION	Session Hijacking ocorre quando um atacante obtém o cookie de sessão de um usuário e o utiliza para se passar por ele. Em cenários onde o atacante controla a rede da vítima, cookies podem ser expostos se forem transmitidos por HTTP.
OBSERVATION	

TEST DETAILS

É possível, através do cookie da sessão uma vez logado, copia-lo em outro computador ou navegador e acessar o sistema apenas colando o cookie, sem precisar de um login.

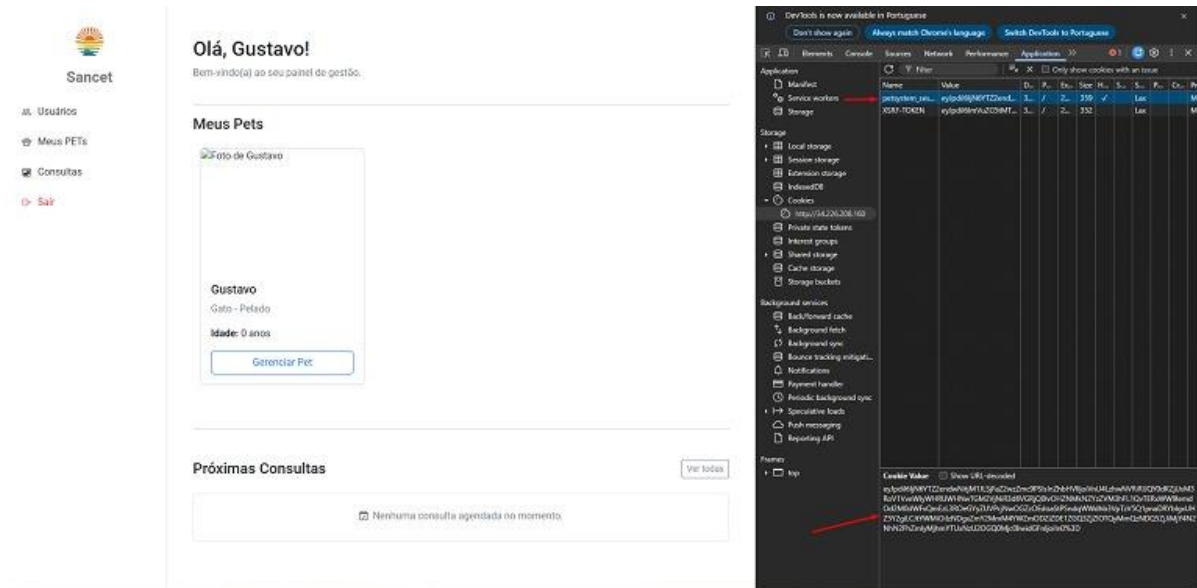


Image 4 – Acessando e copiando o Cookie

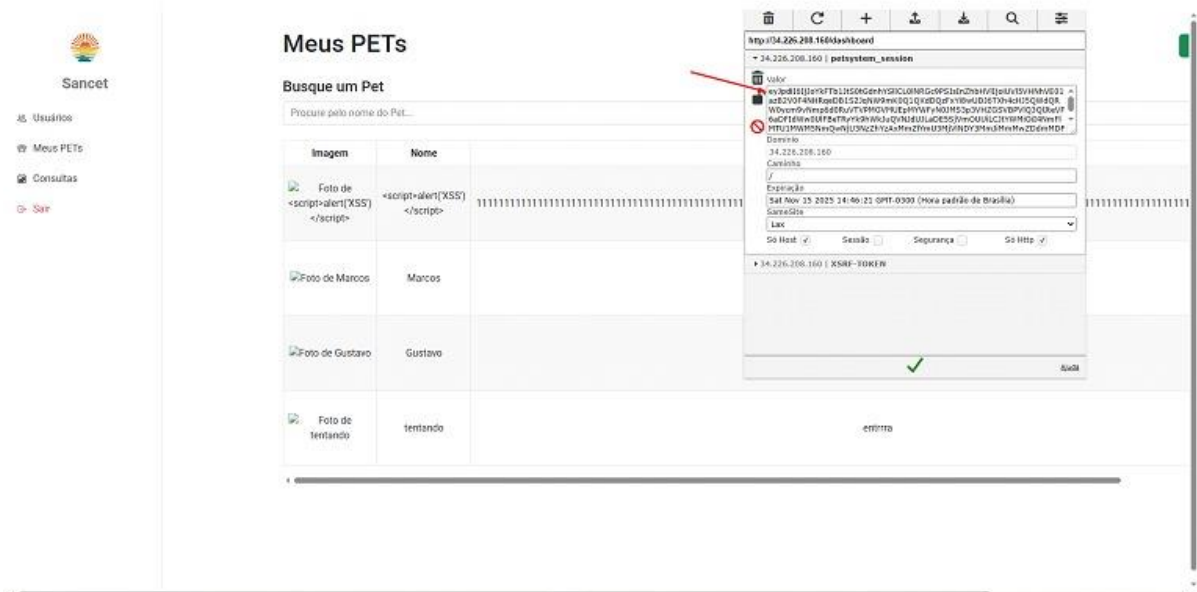


Image 5 – Colando o Cookie em outro navegador



REMEDIATION	Proteger rigorosamente o mecanismo de sessão, garantindo que um atacante não consiga capturar, prever ou reutilizar o identificador de sessão de outro usuário. Implemente renovação do ID de sessão após login, mudanças de privilégio e atividades sensíveis. Utilize conexões HTTPS em toda a aplicação para prevenir interceptação de sessão via rede, Monitore tentativas suspeitas de uso simultâneo da mesma sessão. Estabeleça tempos de expiração curtos para sessões inativas.
REFERENCES	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/06-Session_Management_Testing/09-Testing_for_Session_Hijacking

PRIVILEGE ESCALATION

CVSS SEVERITY	High	CVSSv3 SCORE	8.8
CVSSv3 CRITERIAS	Attack Vector : Local	Scope : Changed	
	Attack Complexity : Low	Confidentiality : High	
	Required Privileges : Low	Integrity : High	
	User Interaction : None	Availability : High	
AFFECTED SCOPE			
DESCRIPTION	Privilege Escalation ocorre quando um usuário consegue acessar funções ou recursos além do que lhe foi permitido, devido a falhas de autorização na aplicação. Isso permite que o sistema execute ações com privilégios maiores do que o previsto pelo desenvolvedor ou administrador.		
OBSERVATION			
TEST DETAILS			
Um usuário comum, tendo descoberto a roda de alteração de usuário, é capaz de acessar a tela e dar permissão de administrador para ele mesmo, além de conseguir dados sensíveis de outros usuários e alterar suas informações.			



Image 6 – Acessando a tela de manutenção de usuário

REMIEDIATION	implemente controles de acesso rigorosos em todas as funcionalidades sensíveis, garantindo que cada ação executada seja validada de acordo com o nível de permissão do usuário autenticado. Garanta que cada endpoint sensível realize verificações de autorização individuais. Use o modelo de controle de acesso recomendado pelo framework utilizado e aplique essas regras de forma centralizada e consistente.
REFERENCES	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/05-Authorization_Testing/03-Testing_for_Privilege_Escalation

INSECURE DIRECT OBJECT REFERENCE (IDOR)

CVSS SEVERITY	High		CVSSv3 SCORE	8.3
CVSSv3 CRITERIAS	Attack Vector :	Network	Scope :	Unchanged
	Attack Complexity :	Low	Confidentiality :	High
	Required Privileges :	Low	Integrity :	High
	User Interaction :	None	Availability :	Low
AFFECTED SCOPE				
DESCRIPTION	IDOR ocorre quando a aplicação permite acesso direto a objetos usando valores fornecidos pelo usuário, sem verificar autorização. Ao alterar parâmetros (como IDs), um atacante pode acessar registros de banco, arquivos ou dados de outros usuários porque o sistema busca o objeto solicitado sem checar se o usuário tem permissão.			



OBSERVATION

TEST DETAILS

Ao editar um PET é possível através da URL acessar PETs que não pertencem ao usuário cadastrado.

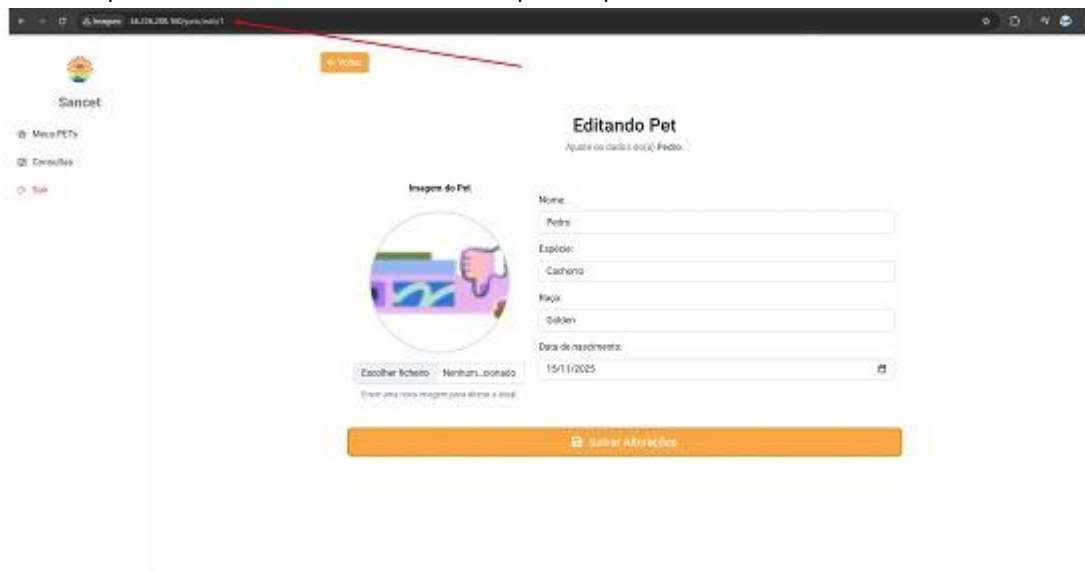


Image 7 – Acessando os dados de PETs alheios

Ao clicar em "Salvar Alterações" foi possível alterar sem nenhum tipo de restrição.

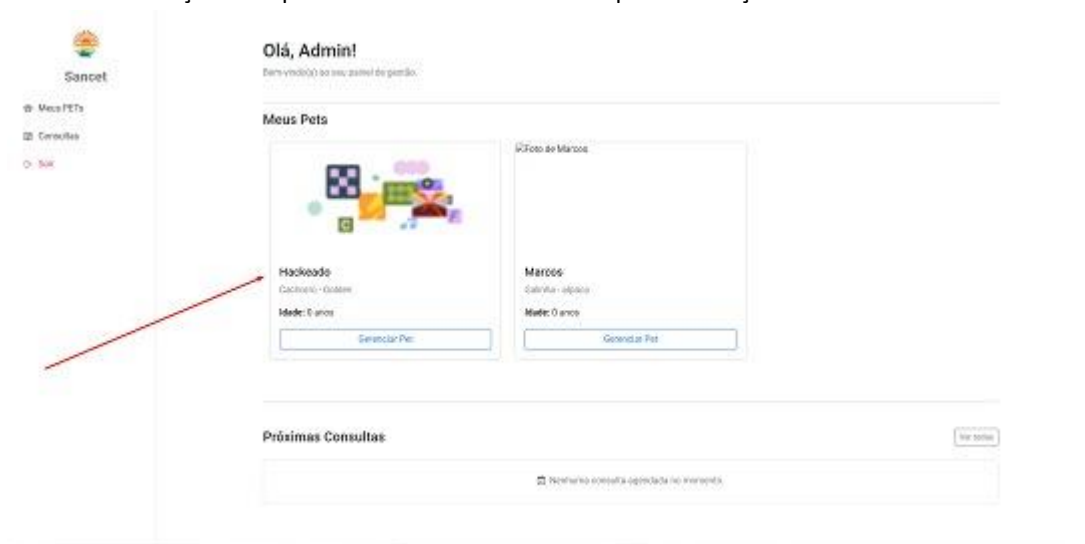


Image 8 – Editado os dados de PETs alheios

REMEDIAÇÃO

Implementar verificações de controle de acesso para cada objeto que o usuário tenta acessar. Ao buscar objetos no banco, consulte apenas os recursos pertencentes ao usuário, e não o conjunto inteiro. Em fluxos de várias etapas, armazene identificadores na sessão para impedir manipulação.

REFERENCES

https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References



CONFIDENTIAL